

Modèle de Harrison-Ruzzo-Ullman (12)

Exemple de commande

- **Création de fichier :**

Command créer-fichier(p,f)

créer_objet(f)

entrer(own,M[p,f])

entrer (r,M[p,f])

entrer (w,M[p,f])

Fin

- **Donner un accès en lecture sur un fichier :**

Command grant-read(p,f,q)

Si

own $\in$ M[p,f]

Alors

entrer(r,M[q,f])

Fin

**Commande qui indique
la création d'un fichier f
par le processus P**

**Commande qui permet à un
sujet p propriétaire du fichier
f d'accorder un accès en
lecture à un autre sujet
q sur ce fichier**

Modèle de Harrison-Ruzzo-Ullman (13)

Exercice

Objets utilisateurs	Fichier1	Fichier 2	Fichier 3	Fichier 4
Ramzi	owns	read	read	
Riad		owns	read, write	owns
Billel	read	read ,write	owns	Read, Write
Nedjma			Read	Read, write

- Définir une commande confer.read qui permet à l'utilisateur Ramzi de donner un accès en lecture sur un fichier 1 à l'utilisateur Riad.

Modèle de Harrison-Ruzzo-Ullman (14)

L'automate d'accessibilité global

si le nombre de sujets et objets créés reste fini, il est possible d'explorer toutes les évolutions possibles du système .

- Cela signifie que dans un système où il y a un nombre limité de sujets (utilisateurs) et d'objets (ressources), il est théoriquement possible d'analyser toutes les combinaisons d'actions possibles que ces sujets peuvent effectuer sur ces objets. Cela permet de déterminer l'état du système à tout moment et de prévoir toutes les évolutions possibles.
- **L'automate d'accessibilité global** est un moyen de représenter toutes les combinaisons d'actions possibles dans un système. Dans cet exemple, l'automate d'accessibilité global montrerait tous les états possibles du système après l'exécution de chaque action. Cela permettrait de visualiser toutes les interactions entre les sujets et les objets et de déterminer les autorisations accordées ou révoquées à chaque étape. Cela aiderait également à identifier les éventuelles incohérences ou violations de sécurité dans le système.

Modèle de Harrison-Ruzzo-Ullman (15)

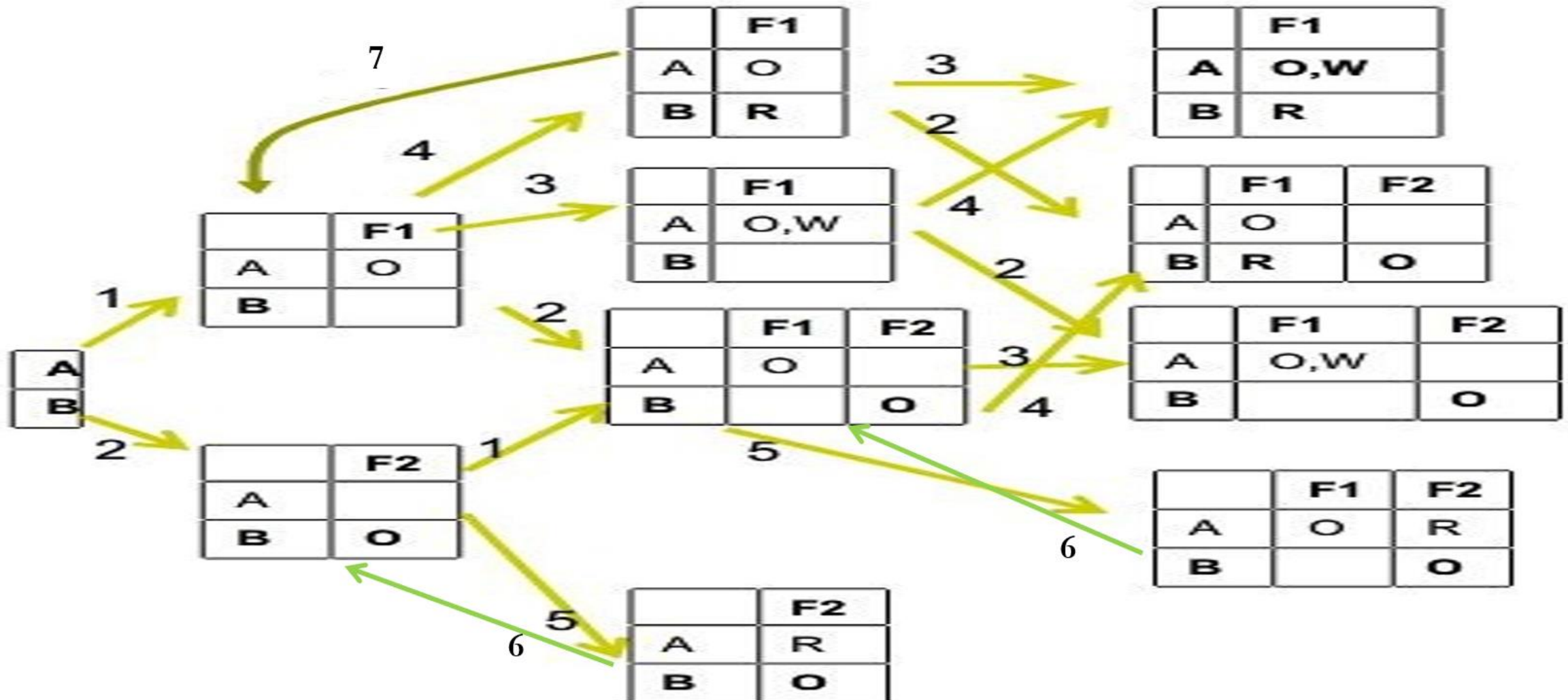
Exemple

Dans l'exemple donné, le système est initialement constitué de deux sujets, A et B, et aucun objet n'est encore créé. Les étapes suivantes décrivent les actions effectuées par ces sujets sur les objets :

1. A crée un objet F1
2. B crée un objet F2
3. A autorise A à écrire dans F1
4. A autorise B à lire dans F1
5. B autorise A à lire F2
6. Si A a le droit de lire F2, B lui retire ce droit
7. Si B a le droit de lire F1, A lui retire ce droit

Modèle de Harrison-Ruzzo-Ullman (16)

L'automate d'accessibilité global de l'exemple



Modèle Take-Grant

Le modèle Take-Grant, introduit par Jones et al. en 1976, est une variante initiale du modèle HRU (Harrison, Ruzzo, Ullman). Il se présente sous la forme d'un graphe dont les nœuds représentent des sujets ou des objets, et les arcs représentent les droits d'accès entre ces entités. Ce modèle offre une alternative à la matrice d'accès pour représenter les autorisations dans un système.

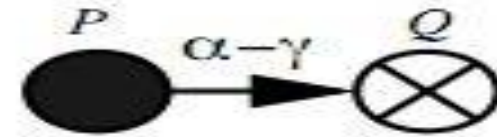
Les principales caractéristiques du modèle Take-Grant sont les suivantes :

1. **Structure du graphe:** Le graphe représente les autorisations d'accès entre les sujets et les objets. Chaque nœud représente un sujet ou un objet, et les arcs représentent les droits d'accès entre eux.
2. **Commandes restreintes:** Les commandes sont réparties en quatre catégories distinctes, ce qui restreint les actions possibles dans le système :
 - **La commande "create"** permet de créer un objet et d'attribuer initialement un droit d'accès à un sujet sur cet objet.
 - **La commande "remove"** permet de retirer un droit d'accès d'un sujet sur un objet.
 - **Les commandes de type "take"** permettent à un sujet possédant le droit spécial "t" sur un autre sujet d'obtenir les droits d'accès que ce sujet possède sur les objets.
 - **Les commandes de type "grant"** permettent à un sujet possédant déjà un droit d'accès sur un objet ainsi que le droit spécial "g" sur un autre sujet de céder ce droit d'accès à ce dernier sujet.

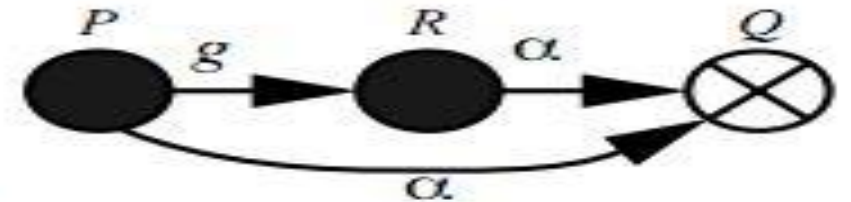
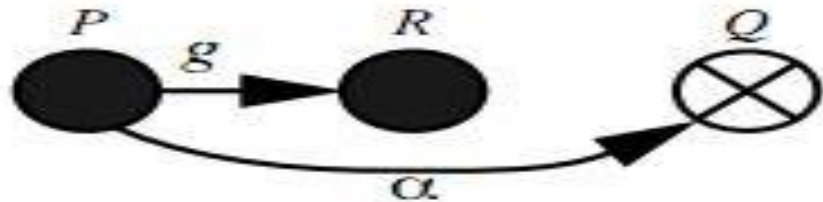
Modèle Take-Grant (2)



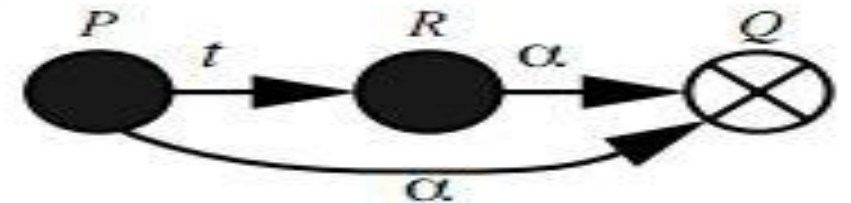
(a) Règle create



(b) Règle remove



(c) Règle grant



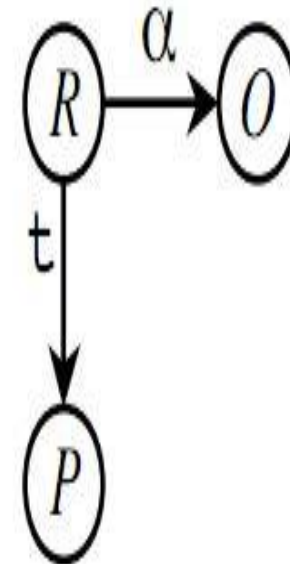
(d) Règle take

Modèle Take-Grant (3)

Les règles de contrôle d'accès peuvent sembler simples individuellement, mais leur combinaison peut conduire le système à des états d'insécurité. En effet, l'application successive de plusieurs règles, lorsqu'elles sont judicieusement choisies, peut entraîner l'octroi de nouveaux droits à des sujets, ce qui peut compromettre certains objectifs de sécurité.

Prenons l'exemple d'un graphe de protection illustré dans la figure suivante, extrait de [Dacier 1994]. Ce graphe contient deux sujets, P et R, ainsi qu'un objet O. Dans l'état de protection initial, le sujet R possède le droit α sur l'objet O et le droit t sur le sujet P.

Considérons un objectif de sécurité stipulant que le système est considéré comme non sécurisé si le sujet P parvient à acquérir le droit α sur l'objet O.



Le modèle MAC

Le contrôle d'accès obligatoire (Mandatory Access Control, MAC) repose sur le principe selon lequel la politique de sécurité appliquée à un système ne peut pas être modifiée par les utilisateurs du système eux-mêmes. Contrairement aux modèles de contrôle d'accès discrétionnaire, où les utilisateurs ont un certain contrôle sur les autorisations d'accès, dans un environnement MAC, l'attribution des permissions est gérée par une entité tierce et les utilisateurs ne peuvent en aucun cas intervenir dans ce processus.

Dans le modèle MAC, les politiques de sécurité imposent que les décisions de protection ne soient pas prises par les propriétaires des objets concernés, mais soient plutôt imposées par le système lui-même. Cela signifie que les règles de sécurité sont incontournables et garantissent l'atteinte des objectifs de sécurité visés.

Dans un système MAC, l'accès aux objets est basé sur le niveau de sensibilité de l'information contenue dans ces objets. L'autorisation d'accéder à un objet est accordée à un sujet si le niveau d'autorisation de ce sujet est en accord avec le niveau de sensibilité de l'information de l'objet.

Par exemple, si un sujet a un niveau d'autorisation qui correspond au niveau de sensibilité requis pour accéder à un certain objet, alors ce sujet sera autorisé à accéder à cet objet. Sinon, l'accès sera refusé.

Le modèle MAC (2)

La sécurité multi-niveaux

La sécurité multi-niveaux est une approche utilisée dans les systèmes informatiques multi-utilisateurs pour gérer les informations en fonction de leur sensibilité. Dans ce modèle, les informations sont classées en différents niveaux de sensibilité, et des mécanismes sont mis en place pour garantir que seuls les utilisateurs autorisés ont accès à des informations sensibles.

Voici quelques points clés à retenir sur la sécurité multi-niveaux :

1. Classification des informations sensibles: Les informations sont classées en fonction de leur importance et de leur sensibilité. Par exemple, certaines informations peuvent être classées comme "Non classifiées", tandis que d'autres peuvent être classées comme "Confidentielles", "Secretes" ou "Top Secret", en fonction du niveau de confidentialité requis.

2. Niveaux de sécurité pour les sujets et les objets: Dans ce modèle, chaque sujet (utilisateur ou processus) et chaque objet (ressource ou fichier) se voient attribuer un niveau de sécurité spécifique. Le niveau de sécurité d'un sujet est souvent appelé "Habilitation", tandis que le niveau de sécurité d'un objet est appelé "Classification". Ces niveaux de sécurité déterminent qui peut accéder à quelles informations.

Le modèle MAC (3)

La sécurité multi-niveaux (2)

3. Contrôle d'accès basé sur les niveaux de sécurité: Les mécanismes de contrôle d'accès sont mis en place pour garantir que seuls les sujets autorisés peuvent accéder à des objets ayant un niveau de classification égal ou inférieur à leur niveau d'habilitation. Par exemple, un utilisateur avec une habilitation "Secret" peut accéder à des informations classées "Confidentielles" mais pas à des informations classées "Top Secret".

4. Protection contre la divulgation non autorisée: L'objectif principal de la sécurité multi-niveaux est de prévenir la divulgation non autorisée d'informations sensibles. En limitant l'accès aux informations en fonction des niveaux de sécurité, le système garantit que seules les personnes autorisées peuvent accéder aux données appropriées, réduisant ainsi les risques de fuites ou de compromissions.

Le modèle MAC (4)

Dans le modèle de contrôle d'accès décrit, les concepts sont présentés à l'aide des notations suivantes :

1. **L**: C'est un ensemble de niveaux de sécurité, représentant les différents niveaux de sensibilité des informations. Ces niveaux sont ordonnés selon une relation d'ordre partiel $\leq$, ce qui signifie qu'un niveau de sécurité peut être inférieur, égal ou supérieur à un autre niveau de sécurité.

2. **fS: S $\rightarrow$ L**: Cette fonction assigne à chaque sujet (utilisateur ou processus) son niveau d'habilitation, c'est-à-dire le niveau de sécurité auquel il est autorisé à accéder. Par exemple, un sujet peut être autorisé à un niveau de sécurité "Confidentiel" ou "Secret".

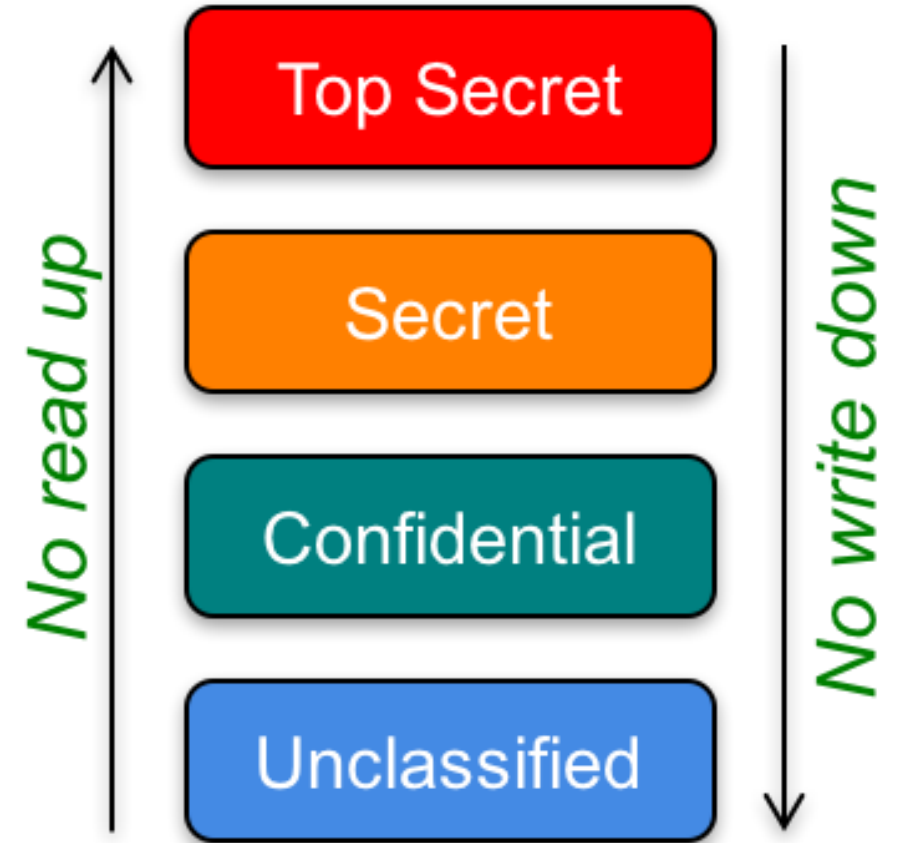
3. **fO: O $\rightarrow$ L**: Cette fonction attribue à chaque objet (ressource ou fichier) sa classification, c'est-à-dire le niveau de sécurité de l'objet lui-même. Par exemple, un fichier peut être classé comme "Confidentiel" ou "Secret".

4. **Mso**: C'est la matrice de contrôle d'accès qui associe à chaque couple (sujet, objet) un ensemble de droits d'accès. Cette matrice détermine les autorisations accordées à chaque sujet pour accéder à chaque objet. Par exemple, un sujet peut avoir le droit de lire ou d'écrire dans un certain objet en fonction de son niveau d'habilitation et de la classification de l'objet.

Le modèle MAC (5)

Dans ce modèle, les règles de contrôle d'accès suivantes sont établies :

- Un sujet est autorisé à lire des informations si son niveau d'habilitation est supérieur à la classification de ces informations. Cela signifie qu'un sujet ne peut lire des informations que s'il a un niveau de sécurité égal ou supérieur à celui des informations.
- Un sujet est autorisé à écrire dans des objets si son niveau d'habilitation est inférieur à la classification de ces objets. Cela signifie qu'un sujet ne peut écrire dans un objet que si son niveau de sécurité est inférieur ou égal à celui de l'objet.



Le modèle de Bell et La Padula

Le modèle de Bell et LaPadula, développé par David Elliott Bell et Len LaPadula pour le département de la défense américaine, formalise la sécurité multi-niveaux et met l'accent sur la confidentialité des données dans divers systèmes informatiques tels que les systèmes d'exploitation et les systèmes de gestion de bases de données.

À la différence du modèle proposé par Lampson, le modèle de Bell et LaPadula se concentre sur les flux d'information plutôt que sur l'accès direct aux ressources. Il est basé sur les concepts de sujets (utilisateurs ou processus), d'objets (ressources ou données) et de modes d'accès, mais il exprime les objectifs de sécurité en termes de circulation et de contrôle des informations plutôt qu'en termes d'accès.

Dans ce modèle, les droits d'accès dépendent des classifications attribuées aux objets et des habilitations attribuées aux sujets. Les classifications représentent les niveaux de sensibilité des informations et les habilitations représentent les niveaux de confiance ou d'autorisation des sujets à quelles ressources.

Le modèle de Bell et La Padula (2)

Les règles obligatoires imposées par le modèle de Bell et LaPadula visent à prévenir la circulation des informations d'un niveau de sécurité élevé vers un niveau de sécurité plus bas. Ces règles assurent que les informations classifiées à un niveau de sécurité élevé ne peuvent être transférées vers des sujets ou des objets classifiés à un niveau de sécurité inférieur, préservant ainsi la confidentialité des données.

De plus, le modèle introduit la notion de niveaux de sécurité formant un ensemble partiellement ordonné ($L; \leq$), où les niveaux de sécurité sont organisés hiérarchiquement pour déterminer les autorisations d'accès en fonction de la sensibilité des informations. Cela permet de définir clairement les restrictions et les autorisations d'accès pour chaque niveau de sécurité, contribuant ainsi à renforcer la sécurité et la confidentialité des systèmes informatiques.

Dans le modèle de Bell et LaPadula, la sécurité est abordée sous l'angle de la circulation et du contrôle des informations plutôt que de l'accès direct aux ressources. Cela signifie que le modèle se concentre sur la manière dont les informations se déplacent à travers le système et sur la manière dont elles sont contrôlées pour garantir la confidentialité et l'intégrité des données, plutôt que sur qui peut accéder.

Le modèle de Bell et La Padula (3)

Dans le modèle de contrôle d'accès de Bell-LaPadula, chaque sujet et chaque objet du système d'information se voient attribuer un niveau de sécurité. Ce niveau de sécurité est crucial pour déterminer les autorisations d'accès des sujets aux objets. Voici quelques points clés pour comprendre ce modèle :

1. Niveau d'habilitation et niveau de classification: Chaque sujet (utilisateur ou processus) se voit attribuer un niveau d'habilitation, tandis que chaque objet (donnée ou ressource) se voit attribuer un niveau de classification. Ces niveaux sont utilisés pour évaluer les autorisations d'accès.

2. Fonctions d'habilitation et de classification: Les fonctions f_s et f_o assignent respectivement les niveaux d'habilitation et de classification aux sujets et aux objets. Ces fonctions déterminent les niveaux de sécurité associés à chaque sujet et à chaque objet dans le système.

La fonction d'habilitation est notée $f_s: S \rightarrow L$ et celle de classification $f_o: O \rightarrow L$.

Le modèle de Bell et La Padula (4)

3. **Propriété de tranquillité forte:** Une caractéristique importante du modèle est la propriété de tranquillité forte, qui stipule que les niveaux de sécurité attribués aux sujets et aux objets ne peuvent pas être modifiés une fois qu'ils ont été établis. Cela garantit la stabilité et la prévisibilité du système de contrôle d'accès.

4. **Propriété de sécurité simple :** La propriété de sécurité simple, également connue sous le nom de principe "no read up", est une règle fondamentale du modèle Bell-LaPadula. Elle stipule qu'un sujet ne peut accéder à un objet que si le niveau d'habilitation du sujet est supérieur ou égal au niveau de classification de l'objet. En d'autres termes, un sujet ne peut pas lire des informations classifiées à un niveau de sécurité plus élevé que le sien. Cette règle vise à prévenir la divulgation non autorisée d'informations sensibles et à garantir la confidentialité des données.

Formellement : $\forall s \in S; \forall o \in O; (s; o; \text{read}) \in M \longrightarrow f_O(o) \leq f_S(s)$

Top secret

O

S

Secret

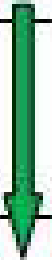
O

S

Confidentiel

S

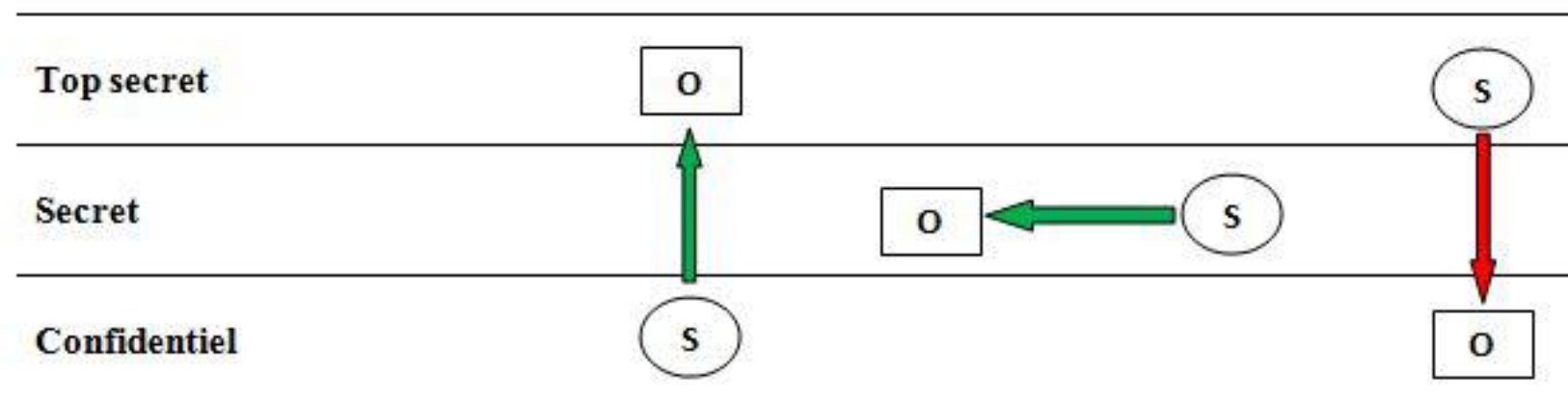
O



Le modèle de Bell et La Padula (5)

5. **La propriété étoile:** La propriété étoile du modèle de sécurité Bell-LaPadula établit une règle fondamentale dans la gestion de la confidentialité des informations : un sujet ne peut écrire dans un objet que si son niveau d'accréditation est inférieur ou égal au niveau de classification de cet objet. Cette règle est résumée par l'expression "ne pas écrire en bas". En d'autres termes, elle garantit que les utilisateurs ne peuvent pas accéder à des informations plus sensibles que leur niveau d'autorisation ne le permet, évitant ainsi les fuites de données et préservant l'intégrité du système.

Formellement : $\forall s \in S; \forall o \in O; (s; o; \text{write}) \in M \Rightarrow f_S(s) \leq f_O(o)$.



Variantes du modèle de Bell et La Padula

Dans le domaine de la sécurité informatique, des variantes du modèle Bell-LaPadula ont été introduites pour offrir plus de souplesse et d'expressivité. Ces variantes traduisent les notions d'observation et de modification de l'information non seulement par les opérations élémentaires de lecture et d'écriture, mais également par d'autres actions telles que l'exécution et l'ajout.

L'action "**Exécuter**" permet un accès à l'information sans la modifier ni l'observer, par exemple dans le cas où un programme est simplement exécuté sans lire ni écrire de données.

L'action "**Lire**" permet d'observer l'information sans la modifier, ce qui peut être utile dans des scénarios où la simple consultation des données est nécessaire.

L'action "**Ajouter**" (ou "append") permet de modifier l'information sans l'observer, par exemple lors de l'ajout de données dans des fichiers de journalisation d'audit ou lors de l'ajout de chemins dans des fichiers de configuration lors de l'installation de logiciels.

Enfin, l'action "**Écrire**" englobe à la fois l'observation et la modification de l'information, permettant ainsi un accès complet aux données.

Ces différentes actions offrent une granularité plus fine dans la gestion des autorisations d'accès aux informations, permettant ainsi de mieux répondre aux besoins spécifiques des applications et des environnements de sécurité.

Le modèle de sécurité peut être représenté par une machine à états où chaque état est défini par un triplet (S, O, M) , où :

S : représente un ensemble de sujets, qui sont les entités (utilisateurs, processus, etc.) qui accèdent aux objets.

O : représente un ensemble d'objets, qui sont les ressources (fichiers, bases de données, etc.) auxquelles les sujets accèdent.

A : représente un ensemble d'opérations d'accès, qui inclut des actions telles que exécuter, lire, ajouter et écrire.

un ensemble de niveaux de sécurité muni d'une relation d'ordre partiel, qui définit la hiérarchie des niveaux de sécurité.

B : représente l'ensemble de tous les états possibles de la machine à états.

M : représente l'ensemble des matrices (M_{so}) où $s \in S$ et $o \in O$. Une matrice M_{so} spécifie les autorisations d'accès des sujets aux objets, indiquant quelles opérations chaque sujet est autorisé à effectuer sur chaque objet.

$F \subset L_s^* \times L_o^* \times L_o$: représente l'ensemble des niveaux de sécurité dans un état donné. f_s est le niveau de sécurité maximal qu'un sujet peut avoir, f_c est le niveau de sécurité actuel de chaque sujet et f_o est la classification de l'objet.

Les deux règles de contrôle d'accès dans le contexte de la sécurité informatique sont les suivantes :

La propriété simple : Cette règle stipule qu'un état est considéré comme sécurisé si, pour chaque sujet s qui observe un objet o , le niveau de sécurité maximal du sujet ($fs(s)$) domine le niveau de sécurité de l'objet ($fo(o)$). Formellement, un état satisfait la propriété simple si pour chaque triplet (s, o, a) dans l'ensemble des états possibles (b), on a $fo(o) \leq fs(s)$. En d'autres termes, un sujet ne peut observer un objet que si son niveau de sécurité est au moins aussi élevé que celui de l'objet.

$$\forall (s, o, a) \in b, \Rightarrow fo(o) \leq fs(s)$$

La propriété étoile : Cette règle indique qu'un état est considéré comme sécurisé si, pour chaque sujet s qui modifie un objet o , le niveau de sécurité de l'objet ($fo(o)$) domine le niveau courant de sécurité du sujet ($fc(s)$). Formellement, un état est considéré comme sécurisé si pour chaque triplet (s, o, a) dans l'ensemble des états possibles (b), on a $fc(s) \leq fo(o)$. En d'autres termes, un sujet ne peut modifier un objet que si le niveau de sécurité de l'objet est au moins aussi élevé que le niveau de sécurité actuel du sujet.

$$\forall (s, o, a) \in b, \Rightarrow fc(s) \leq fo(o)$$

En résumé, ces deux règles de contrôle d'accès garantissent que les sujets ne peuvent observer ou modifier des objets que s'ils ont un niveau de sécurité approprié, assurant ainsi l'intégrité et la confidentialité des données dans les systèmes informatiques.

Le modèle de Biba 1977

Les politiques obligatoires sont des règles de sécurité développées pour maintenir l'intégrité des données dans les systèmes informatiques. Elles appliquent à l'intégrité un modèle similaire à celui de Bell-LaPadula, qui est utilisé pour la confidentialité.

Selon ces politiques, chaque sujet se voit attribuer un niveau d'intégrité (is(s)), correspondant à la confiance accordée à ce sujet, et chaque objet possède un niveau d'intégrité (io(o)), correspondant au niveau d'intégrité du sujet qui l'a créé. Les objectifs de sécurité de cette politique visent à :

Interdire toute propagation d'information d'un objet situé à un certain niveau d'intégrité vers un objet situé à un niveau d'intégrité supérieur. Cela garantit que les données ne peuvent pas être modifiées ou altérées par des sujets de confiance inférieure, préservant ainsi leur intégrité.

Interdire à tout sujet situé à un certain niveau d'intégrité de modifier un objet possédant un niveau d'intégrité supérieur. Cela garantit que les sujets de confiance inférieure ne peuvent pas altérer les données créées par des sujets de confiance supérieure, préservant ainsi leur intégrité et évitant toute altération ou corruption non autorisée.

Le modèle de Biba 1977 (2)

Le schéma d'autorisation en matière de sécurité découle de la recherche de certaines propriétés, en tenant compte des labels d'intégrité et du regroupement des opérations en trois classes : observation, modification et invocation.

Un sujet ne peut modifier un objet que si le label d'intégrité du sujet domine le label d'intégrité de l'objet :

$$(si, oj, modifier) \Rightarrow io(oj) \leq is(si).$$

Cette règle garantit que seuls les sujets dont le niveau d'intégrité est au moins aussi élevé que celui de l'objet peuvent modifier cet objet, préservant ainsi l'intégrité des données.

Un sujet ne peut observer un objet que si le label d'intégrité de l'objet domine le label d'intégrité du sujet :

$$(si, oj, observer) \Rightarrow is(si) \leq io(oj).$$

Cette règle assure que seuls les sujets dont le niveau d'intégrité est inférieur ou égal à celui de l'objet peuvent observer cet objet, évitant ainsi toute divulgation non autorisée d'informations sensibles.

Un sujet ne peut invoquer un sujet j que si le label d'intégrité de si domine le label d'intégrité de sj :

$$(si, sj, invoquer) \Rightarrow is(sj) \leq is(si).$$

Cette règle garantit que seuls les sujets dont le niveau d'intégrité est au moins aussi élevé que celui du sujet invoqué peuvent effectuer cette action, préservant ainsi la sécurité du système en limitant les accès aux sujets de confiance suffisante.

Le modèle Clark et Wilson

Dans l'environnement commercial, la prévention contre les modifications non autorisées de l'information, notamment contre les fraudes et les erreurs, est d'une importance capitale. Même si un utilisateur est autorisé à manipuler certaines données, cela ne doit pas entraîner de perte ou de falsification des actifs, tels que les capitaux et les informations.

La politique de Clarke-Wilson repose sur deux principes bien connus :

Transactions bien formées : Ce principe stipule que les utilisateurs n'ont pas le droit de manipuler les données de manière arbitraire, mais seulement à travers des procédures de transformation spécifiques qui préservent l'intégrité des données. Les actions des utilisateurs doivent suivre des protocoles prédéfinis et autorisés pour garantir que les données restent exactes et fiables.

Séparation des pouvoirs : Aussi connue sous le nom de "separation of duty", ce mécanisme de contrôle des fraudes et des erreurs est basé sur la répartition des opérations entre plusieurs parties et l'attribution de droits différents mais complémentaires à différentes catégories de personnes. En séparant les responsabilités et les autorisations entre plusieurs individus ou entités, ce principe réduit les risques de fraudes et d'erreurs en obligeant plusieurs personnes à s'impliquer dans un processus de validation ou de transaction.

Le modèle Clark et Wilson (2)

Dans ce modèle, plusieurs concepts clés doivent être définis pour assurer la sécurité des données :

1.Les données contraintes (CDI) : Ces données représentent les éléments de données dont nous voulons préserver l'intégrité. Elles sont soumises à des contraintes et à des mécanismes de protection pour garantir qu'elles ne sont pas altérées de manière non autorisée.

2.Les données non contraintes (UDI) : Ces données représentent les éléments dont l'intégrité n'est pas garantie et qui peuvent être manipulés de manière arbitraire. Elles ne sont pas soumises aux mêmes contraintes de protection que les CDI.

3.Procédures pour la vérification de l'intégrité (IVP) : Ces procédures sont utilisées pour confirmer que tous les CDI dans les systèmes sont conformes aux spécifications d'intégrité au moment où les IVP sont exécutées. Elles permettent de s'assurer que les données contraintes restent intactes et non altérées.

4.Procédures de transformation (TP) : Correspondant au concept de transactions bien formées, ces procédures visent à changer les CDI d'un état valide à un autre état valide. Elles permettent des modifications contrôlées et autorisées des données contraintes tout en préservant leur intégrité et leur fiabilité.

Le modèle Clark et Wilson (3)

Dans le modèle de sécurité de Clarke-Wilson, les règles appliquées dans leur politique de sécurité sont définies de la manière suivante :

L'ensemble des utilisateurs, noté $U=\{u_1, u_2, \dots\}$.

L'ensemble des données contraintes, $CDI=\{CDI_1, CDI_2, \dots\}$.

L'ensemble des données non contraintes, $UDI=\{UDI_1, UDI_2, \dots\}$.

L'ensemble des opérations de vérification de l'intégrité des données, $IVP=\{IVP_1, IVP_2, \dots\}$. Ainsi, les CDI sont certifiées par des IVP.

L'ensemble des opérations de transformation des données (Transformation Procedures), noté $TP=\{TP_1, TP_2, \dots\}$. Les CDI ne peuvent être manipulées que par des TP.

Une relation R_c liant chaque opération de transformation TP_i à un sous-ensemble c de CDI ; R_c précise les données que l'opération peut manipuler.

Une relation R_u liant chaque utilisateur u et chaque opération de transformation TP_i à un sous-ensemble de CDI ; R_u précise les données contraintes qu'un utilisateur est autorisé à manipuler (par le biais de TP_i).

Le modèle Clark et Wilson (4)

Les règles obligatoires du modèle de Clarke-Wilson imposent plusieurs contraintes :

Les CDI doivent être dans un état valide, vérifié par les IVP. Cela garantit que les données contraintes sont toujours fiables et conformes aux spécifications d'intégrité.

Toutes les opérations de TP doivent être certifiées. Si une donnée contrainte est valide avant l'exécution d'une opération TP_i , elle doit rester valide après l'exécution de TP_i . De plus, les opérations de TP ne peuvent être effectuées que sur des données contraintes spécifiées par R_c .

Chaque utilisateur n'effectue des opérations de transformations sur des données contraintes que si celles-ci lui sont associées par R_u . Cela garantit que chaque utilisateur ne peut manipuler que les données auxquelles il est autorisé.

Le modèle Clark et Wilson (5)

La relation Ru doit être certifiée afin de refléter les besoins de la séparation des pouvoirs. Cela assure que les droits et les autorisations des utilisateurs sont correctement définis et respectés.

Le système doit authentifier l'identité de chaque utilisateur souhaitant exécuter une opération de TP. Cela garantit que seuls les utilisateurs autorisés peuvent effectuer des opérations sur les données.

Avant d'être exécutées, les opérations de TP doivent enregistrer leurs identifiants dans les journaux d'audit, qui sont considérés comme des données contraintes. Cela permet de garder une trace des actions effectuées sur les données et de garantir la traçabilité des opérations.

Chaque opération TP qui accepte une donnée UDI en entrée doit garantir que, quelle que soit la valeur de UDI, elle n'effectue que des transformations conduisant à une donnée contrainte valide (CDIk) ou rejette UDI si elle ne peut pas être transformée de manière valide. Cela assure que seules les données contraintes sont manipulées de manière sécurisée dans le système.

Le modèle Muraille de chine

Le modèle de Brewer et Nash, également connu sous le nom de modèle de la muraille de Chine, est un modèle de contrôle d'accès qui fournit un contrôle d'accès à l'information pouvant évoluer dynamiquement.

Ce modèle a été développé pour réduire les conflits d'intérêts dans des organisations commerciales et assurer la propriété de la confidentialité. Un conflit d'intérêts (COI) survient lorsqu'un sujet accède aux informations confidentielles de deux organisations en compétition, permettant ainsi un flux d'information d'une organisation vers une autre.

Les concepts clés de ce modèle incluent :

- **Objet** : qui est un élément appartenant à une organisation.
- **Organisation** : qui dispose de plusieurs objets utilisés dans le cadre de ses services.
- **Classe de conflits d'intérêts** : qui regroupe des organisations qui sont en concurrence les unes avec les autres.

Le modèle Muraille de chine (2)

Dans ce modèle, le système classe l'information en trois niveaux hiérarchiques :

1.Au niveau le plus bas, on trouve les données simples, telles que les fichiers, qui sont les objets du système.

2.Au niveau intermédiaire, les objets sont regroupés selon la compagnie à laquelle ils appartiennent, formant des ensembles de données (CD).

3.Au niveau le plus élevé, les compagnies sont regroupées en fonction de leur compétitivité ou de leur absence de compétitivité. Cela forme les classes de conflit d'intérêt (COD) mentionnées précédemment.

Les auteurs introduisent une matrice N qui contient l'historique des accès précédemment effectués. Il s'agit de placer les sujets en lignes et les objets en colonnes, où chaque case contient un booléen indiquant si un accès a déjà eu lieu pour le couple (sujet, objet) correspondant. Ainsi, deux règles régissent les accès entre sujets et objets :

•**Simple property** : L'accès en lecture à un objet est autorisé si :

- Il appartient à la même compagnie qu'un objet déjà accédé.
- Ou s'il appartient à une autre classe de conflit d'intérêt que les objets déjà en accès.

•**Étoile (*)-property** : L'accès en écriture à un objet est autorisé si :

- L'accès est autorisé par la règle de sécurité simple.
- Et si le sujet ne peut pas lire aucun objet d'une autre compagnie contenant des informations non stérilisées.